

Semana 5

Construccion de escenarios simulados

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha: 11/02/26

Escenario simulado de generación de alertas de ransomware

El ransomware se encarga de restringir el acceso a sistemas o datos mediante cifrado, generalmente acompañado de exigencias financieras las variantes actuales incluyen esquemas de doble extorsión, donde se extraen datos además del cifrado en este contexto, herramientas como SIEM, IDS y EDR permiten identificar patrones inusuales y generar alertas oportunas.

Escenarios simulados

1. universidad estatal

El ataque comienza con un ataque de phishing dirigido al personal administrativo. Después de ejecutar un archivo malicioso, se detectan comunicaciones con servidores sospechosos, intentos de autenticación inusuales y cifrado de archivos de gran tamaño. El sistema SIEM genera alertas críticas por comportamiento inusual y la creación de notas de rescate. La respuesta rápida evita el impacto general de los sistemas académicos.

2. Hospital Estatal

El incidente está relacionado con la explotación de una vulnerabilidad de servidor abierto. Las alertas incluyen intentos de acceso no autorizados, desactivación de antivirus y actividad de cifrado detectada por EDR la intervención temprana permite restaurar los sistemas clínicos a partir de copias de seguridad, minimizando el impacto en la atención médica.

3. Negocio financiero

El acceso se proporciona mediante credenciales comprometidas. Se generan alertas para inicios de sesión desde ubicaciones inusuales, transferencias masivas de datos y patrones de cifrado compatibles con ransomware la detección temprana bloquea la exfiltración y reduce los riesgos regulatorios.

Conclusiones

Los escenarios muestran que las alertas relacionadas con ransomware se activan a partir de una serie de eventos sospechosos, como accesos inusuales, transferencias de datos inusuales y cifrado masivo la implementación de monitoreo continuo y planes de respuesta estructurados es fundamental para minimizar el impacto operativo y reputacional de estos ataques.

Análisis de comportamiento de eventos de ransomware

El comportamiento de los eventos observados en los escenarios simulados muestra una secuencia progresiva y correlacionada típica de los ataques de ransomware. En primer lugar, se identifica el primer caso de acceso no autorizado, normalmente relacionado con phishing o explotación de una vulnerabilidad este evento se caracteriza por indicadores como iniciar sesión desde ubicaciones inusuales, múltiples intentos fallidos de autenticación o ejecutar archivos no reconocidos.

Luego viene una fase de movimiento lateral y escalada de privilegios, que se refleja en el aumento del tráfico interno la creación de nuevas cuentas administrativas o el abuso de herramientas legítimas de sistemas estos acontecimientos, si bien individualmente pueden parecer legítimos, adquieren significado cuando se vinculan temporalmente.

En la siguiente fase, los sistemas de seguimiento detectan comportamientos inusuales y de alto impacto, como la desactivación de soluciones antivirus, la compresión masiva de archivos o la modificación acelerada de extensiones, indicando la fase de cifrado finalmente, pueden ocurrir eventos de exfiltración de datos, como lo demuestran las transferencias inusualmente grandes a direcciones externas.

Línea de tiempo de detención de incidentes

Descripción cronológica del evento.

08:15 a.m. Recibir correo electrónico malicioso

El usuario recibe un correo electrónico de phishing con un archivo adjunto fraudulento. El sistema de filtrado no la clasifica como amenaza crítica.

08:22 a.m. Ejecución de archivos maliciosos

Se ejecuta el archivo adjunto. EDR registra la creación de un proceso inusual de y genera una alerta de gravedad media para comportamientos sospechosos.

08:25 a.m. Comunicación con servidor externo

El firewall detecta el tráfico saliente hacia un dominio clasificado como malicioso el SIEM correlaciona el evento con la alerta anterior y eleva el nivel de gravedad a alto.

08:32 a.m. Intentos de autenticación fallidos

Se registran varios intentos fallidos de acceder a otras computadoras en la red, seguidos de un inicio de sesión exitoso. Se genera una alarma por posible movimiento lateral.

08:40 a.m. Desactivación de antivirus

El sistema detecta cambios no autorizados en los servicios de seguridad se emite una advertencia crítica.

08:47 a.m. Comience con cifrado masivo

EDR identifica cambios acelerados de archivos y cambios masivos de extensiones. Se confirma el comportamiento compatible con ransomware.

08:50 a.m. Activando el protocolo de respuesta

El equipo de seguridad aísla la computadora afectada, bloqueado las credenciales comprometidas y activa un plan de contingencia.

Documentación de simulación de incidente

Establecer objetivos

El objetivo de la simulación era analizar la generación y correlación de alertas en caso de un incidente de ransomware en un entorno organizacional controlado para evaluar la capacidad de detección temprana y respuesta de un sistema de monitoreo de seguridad.

Ámbito de actividad La simulación se desarrolló en un entorno virtualizado que representó la infraestructura básica de una organización mediana,

incluyendo: Servidor de archivos servidor de autenticación cinco estaciones de trabajo sistema SIEM para correlación de eventos solución EDR instalada en endpoints no se utilizó ningún malware real; Para evitar riesgos operativos, se imitó el comportamiento típico del ransomware.

Método

La simulación se realizó en cuatro fases

Acceso inicial se simuló un ataque de phishing que conducía a la ejecución controlada de un script que generaba eventos de comportamiento sospechosos.

Movimiento lateral se emularon intentos fallidos de autenticación e inicios de sesión exitosos con credenciales comprometidas para generar registros de errores.

Escalada y evitación se simuló la desactivación de servicios de seguridad y la creación de tareas programadas.

Cifrado simulado se ejecutó un script que cambió las extensiones del archivo de prueba para replicar los patrones de cifrado masivo sin afectar la información real.

Resultados

El SIEM generó alertas graduadas de gravedad media, alta y crítica principalmente por los siguientes motivos

Realización de procesos inusuales contactar con dominios sospechosos el Incremento anormal del tráfico interno los Cambios masivo de archivos la correlación temporal permitió identificar un evento antes de que el impacto fuera generalizado.

Conclusión

La simulación demostró que la detección efectiva de ransomware depende de la correlación entre múltiples eventos y el monitoreo continuo también enfatizó la importancia de establecer protocolos de respuesta bien definidos para minimizar el impacto operativo.

Referencias

Wang, S., Dong, F., Yang, H., Xu, J., & Wang, H. (2024). *CanCal: Towards real-time and lightweight ransomware detection and response in industrial environments*. ArXiv.

Rollere, I., Hartsfield, C., Courtenay, S., Fenwick, L., & Grunwald, A. (2025). *Algorithmic segmentation and behavioral profiling for ransomware detection using temporal-correlation graphs*. ArXiv

Ahmed, M. E., Kim, H., Camtepe, S., & Nepal, S. (2021). *Peeler: Profiling kernel-level events to detect ransomware*. ArXiv.

Earlier Decision on Detection of Ransomware Identification: *A comprehensive systematic literature review*. (2025). *Information*, 15(8), 484.